Document History:

Release Date	Revision No	Author(s)	Description	Reviewed & Approved By	Next review date
15-Sep-2021	1.0	ISO	Approved Document	ISMC	Sep-2022
15-Sep-2022	1.0	ISO	Annual Review	ISMC	Sep-2023
04-Sep-2023	2.0	ISO	Amendments were made to the Use of XYZ IT services personally owned devices	ISMC	Sep-2024
01-Mar-2025	3.0	ISO	Amendments done as per new requirements of the standard	ISMC	March-2026

CS5292 W6 · D15 · sanitised for teaching

Contents

1. PURPOSE 2

2. SCOPE 2

3. WHAT IS INFORMATION SECURITY? 3

4. INFORMATION SYSTEM USAGE 3-4

5. AUTHENTICATION 4

6. E-MAIL AND MESSAGING 6

7. INTERNET USAGE 8

8. REMOTE ACCESS SERVICE 10

9. USE OF XYZ IT SERVICES ON COMPANY OWNED DEVICES 11

10. USE OF XYZ IT SERVICES ON PERSONALLY OWNED DEVICES 12

11. USE OF FLASH DRIVES AND OTHER REMOVABLE MEDIA FOR STORAGE OF COMPANY-OWNED DATA 14

12. EVALUATION AND MONITORING 15

13. NON-COMPLIANCE 15

14. RESPONSIBILITY 16

15. VALIDITY OF THE XYZ INFORMATION SYSTEM USAGE POLICY 16

16. DEFINITIONS 16

PURPOSE

1.1. XYZ provides its employees and authorized third parties with access to its information systems and IT services, based on the job/engagement requirements in a secure, effective, and efficient manner.

1.2. The IT services provided include (but not limited to):

- Access to computing devices;
- Access to print services;
- Access to corporate email services;
- Access to business applications and data;
- Access to the Internet and cloud storage; and
- Access to intranet and file shares.

1.3. This policy establishes a clear, reasonable, secure, and fair standard for the acceptable usage of such information systems and IT services provided by XYZ to its employees and third-party users.



SCOPE

2.1. This XYZ Information System Usage Policy shall apply to the following parties/groups:

- All permanent (including fixed term / contractual employees), and non-permanent employees, which shall include consultants and interns engaged with XYZ under contractual terms or letters of engagement ("Employees");
- Advisors, non-executive directors and advisory board members ("Advisors");
- All corporate and individual visitors to XYZ premises ("Visitors");
- All suppliers, sub-contractors, and their agents XYZ deals with ("Suppliers"); and
- All XYZ customers and their agents XYZ engage with ("Customers"); who in the course of their engagement with XYZ, have been provided access to XYZ information systems and IT services For easy reference all the above will and together shall be referred to as "Users".

2.2. XYZ information system users and relevant third parties must read, understand, and formally accept this Information System Usage Policy before accessing XYZ information systems and IT services.

2.3. XYZ information system users and third parties having access to XYZ Holdings information systems and IT services shall, at all times, comply with the Confidentiality Policy, Information Security Policy, and this Information System Usage Policy.

CS5292 W6 · D15 · sanitised for teaching

2.4. Any non-compliance or violation of the Information Security Policy or this Information System Usage Policy shall be considered an information security violation and may lead to disciplinary actions according to HR policies or for third parties' consequences as result of violating a contractual obligation.

3. WHAT IS INFORMATION SECURITY?

3.1. Information security is the process and practice of protecting the company's sensitive and business-critical information assets, in electronic or physical form, from unauthorized access, use, disclosure, disruption, modification, interception, recording, or destruction.

3.2. The main goals of information security at XYZ are to ensure:

3.2.1. Confidentiality of information - Sensitive Customer, Supplier, and XYZ information shall only be accessible to those authorized to access such information.

3.2.2. Integrity of information - Business Critical Customer, Supplier, and XYZ information shall remain accurate, error-free, and without omissions.

3.2.3. Availability of information - Authorized users shall have access to critical business information when required; and

3.2.4. Non-repudiation of electronic transactions – Users shall be held accountable for their actions in electronic transactions.

NB: An information asset is a definable piece of information, stored in any manner, which is recognized as 'valuable' to the company.

4. INFORMATION SYSTEM USAGE

4.1. Users must take due care to protect XYZ IT systems and information assets from tampering and /or accidental damage.

4.1.1. All XYZ information systems, including desktops, laptops, mobile devices, printers, fax machines, and photocopiers, as well as networks, servers, and applications must only be used for the intended and authorized business purposes.

4.1.2. Users are not permitted to use XYZ Information Systems for illegal or unlawful purposes.

4.2. Illegal or unlawful use of IT systems

Illegal or unlawful uses of IT systems include but are not limited to copyright infringement, fraud, defamation, plagiarism, harassment, intimidation, obscenity, forgery, impersonation, gambling,

computer tampering (e.g. spreading computer viruses, etc.), or unauthorized computer access.

4.3. Users must only install and use licensed software applications that are properly authorized and pre-approved by the Chief Digital Officer.

4.3.1. Users with administrative rights must not disable or bypass any controls, such as antivirus software, proxy servers, and firewalls, implemented to protect XYZ networks and information assets.

4.3.2. Users must not post sensitive or confidential information about XYZ, its Suppliers, or Customers, on publicly accessible Internet sites, such as social media sites, chat services, mailing lists, blogs, or public newsgroups.

4.3.3. Any User intending to post information about XYZ, its Suppliers, or Customers, on publicly accessible Internet sites, must first obtain approval from Group Corporate Communications.

4.3.4. Users shall obtain appropriate intellectual property rights/copyrights or contractual clearances before using any proprietary material.

4.3.5. Users shall not transmit sensitive or confidential information, over the network, without adequate protection controls. If required, the user must first obtain approval from Group Corporate Communications.

NB: If a User needs support in communicating sensitive or confidential information, he or she must contact the IT Help Desk or the SBU/division IT representative.
NB: Users must not disclose, communicate, or discuss in public, any of XYZ, its Suppliers', or Customers' sensitive or confidential information.

4.3.6. Users shall be aware and should refrain from being victims of the attempts of social engineering such as phishing, business email compromise, etc., corporate espionage, and competitive intelligence gathering through electronic media.

4.3.7. Users must not post any sensitive or confidential information about XYZ, its suppliers, or customers on Artificial intelligence platforms such as ChatGPT.

4.4. Users are strongly advised not to store any personal data/information in XYZ provided computing devices. Further XYZ will not be responsible for any breaches for such information that are stored in XYZ provided computing devices.

4.5. Periodically, XYZ will conduct information security awareness and training sessions. All users are required to participate in such training when invited.

4.6. Users must exercise caution when printing confidential information using shared printers, which are designated solely for official purposes.

4.7. It is the user's responsibility to ensure that company workstations are adequately secured and that no third party can intentionally or unintentionally view the work carried out on these computing devices.

5. AUTHENTICATION

Authentication is how the organization identifies that it is you who is accessing XYZ systems.

XYZ will, at its discretion, introduce different solutions that help to increase the protection of critical data across the organization. These tools give real-time visibility and control over access and activities performed by users within each application. Identities will get blocked if any suspicious activity is detected and, in such instances, users must contact their IT administrators to unblock the account.

5.1 PASSWORD PROTECTION

Users are personally accountable for all events that occur under their login accounts. Therefore, users are responsible for keeping their passwords confidential.

5.1.1. Under no circumstance shall Users give, tell, share, or hint at their password to another person (including IT staff, service providers, superiors, other co-workers, friends, or family members).

5.1.2. Users shall not use the "remember password" feature of applications (such as Web Browsers, email programs, etc.).

5.1.3. Users shall change their passwords every 60 days. Once changed, the user will need to wait 24 hours before it can be changed again.

5.1.4. Users must use new passwords that they would be able to easily remember but which would be difficult for anyone else to guess.

5.1.5. Clear text passwords shall not be transmitted over public internet connections.

5.1.6. Users must not use dictionary words or combinations as passwords.

5.1.7. Users must not use the same passwords they use for personal purposes (such as accessing Hotmail, Gmail, Skype, or Internet Banking) to access the company network.

5.1.8. Users must use long passwords containing a mix of alphanumeric and special characters. Passwords should not be based on well-known or easily accessible personal information (such as spouse name, pet name, middle name, child's name, etc.).

CS5292 W6 · D15 · sanitised for teaching

5.1.9. Password Requirements

- Passwords must be more than 10 or more characters long;
- Passwords must include:
- Uppercase and lowercase alphanumeric characters (A-Z, a-z);
- Numbers (0-9); and
- Special Characters (!@#$%^&*)

5.1.10. Users must use the Password Self-Service facility to reset or change their passwords through the password self-service portal.

5.1.11. Users are strictly prohibited from recording their passwords on sticky notes, books, or other printed materials. Additionally, passwords must not be stored in plain text format.

5.2. MULTI-FACTOR AUTHENTICATION (MFA) - Identities are protected with MFA for certain applications as a compulsory factor. Any unsupported/ legacy applications must be authenticated with App passwords.

When users sign into any service or MFA-protected application offered by XYZ with their password, they will also be required to respond to confirm the login from a registered device. For this purpose, the users must set up one or more of the below verification options as their second verification method.

- Authentication Phone
- Office Phone
- Alternate Authentication Phone
- Authenticator App

NB: If a User either knows or suspects that his / her password has been compromised, it must be reported to the IT Help Desk or the SBU / division IT representative and the password should be changed immediately.

5.1.12. Passwords should not be written down or stored in clearly visible or accessible places.



E-MAIL AND MESSAGING

Users are encouraged to use company-provided email, messaging, and corporate social networking services to collaborate and further the goals and objectives of XYZ as well as to fulfill business and role-oriented tasks.

6.1. At all times, Users must be mindful about any content shared or posted on the company-supplied email, messaging, and corporate social networking tools to avoid disclosure of XYZ, its Suppliers' or

Customers' sensitive or confidential information.

6.1.1. Users must not use company email for non-official purposes or as a method of sending non-official email.

6.1.2. Users must not use or share the company email ID provided by the company, for non-official purposes, either as a login for personal use or as a method of accessing personal websites and any consumer PC or mobile/PC application that is owned and paid for by the user.

6.1.3. Content not relevant to work-related purposes must not be circulated without explicit approval from Group Corporate Communications.

6.2. At XYZ, the provided email and the facility provided by Microsoft Teams in Microsoft 365 shall be the formal mode of electronic communication and users are expected to check their emails and their Team-chat messages as well as Yammer posts, in a consistent and timely manner so that they are aware of important appointments, tasks, messages announcements, and updates.

6.3. Users are responsible for their respective mailbox management, including organization, archival, and clearing.

6.3.1. There is an Email size limit. Please consult your site IT representative for further information.

6.4. Protect Your E-mail Account / Password

6.4.1. The email account and password will uniquely identify a User to the email system. Any actions performed using the email account will be indicated in the system as actions carried out by a specific User. Therefore, in case of fraudulent or unauthorized activity committed using a compromised or shared email account, it will be attributed to the specific owner of that email account.

6.5. Email access at XYZ is controlled through individual accounts and passwords. It is the user's responsibility to protect the confidentiality of their account and password information.

6.6. Users shall use the organization's standard email signature template with appropriate disclaimers in all business-related email communications.

6.7. Users are not permitted to use any other user's email account by him/her or on behalf of that user unless authorized to do so.

6.8. Users shall not open, execute, or store emails and attachments received from unknown or untrusted sources and shall report the presence of such emails or attachments to the IT Help Desk. All externally originated emails prepend the tag "[External Email]" to indicate that the message has arrived from outside the organization.

6.9. Emails containing confidential or sensitive content or attachments must be protected and handled in line with the Confidentiality Policy.

6.10. Users are not permitted to use personal email services (such as Hotmail, Yahoo Mail, or Gmail) for business messaging purposes.

6.11. Users are cautioned when using Social Media networks or public chat services (such as WhatsApp, Skype, Google Talk, etc.) for business purposes since those users must bear the risk of violating the Organization's rules for Information Protection. For more information, please refer to the social media, Policy.

6.12. The users are required to continually reach out to their IT support team to check on the availability of equivalent enterprise-specified apps and services before deciding on using the public device apps and services.

6.13. Users are not permitted to post any content or comments, using their office email addresses, to public social media sites, chat services, mailing lists, or news groups. If in case such a posting is required to be performed in the normal course of business duties, appropriate pre-approval must be sought from Group Corporate Communications

6.14. Protect Confidential / Sensitive Emails

> Users are encouraged to use the Information Protection functionality provided with their email and Office applications to protect confidential and sensitive email content and attachments from unauthorized access.

6.15. Users' email, messaging, and corporate social networking access shall be terminated when the Users terminate their association with XYZ.

6.16. Users are prohibited from using email in a manner that is disruptive, harmful, or offensive to others. This includes accessing, displaying, or transmitting politically sensitive material or obscene content, such as pornographic or abusive material, and using ethnic slurs or engaging in any activity that may be construed as harassment or disparagement of others.

6.17. Users are strictly prohibited from misrepresenting themselves as another user or attempting to modify or gain access to email messages, mailboxes, or archive files that do not belong to them.

6.18. The forwarding of chain emails, junk mail, jokes, politically sensitive material, non-business executable files, non-business-related slideshows, videos, images, music files, and any other unsolicited emails or materials deemed a threat to XYZ systems and reputation is strictly forbidden.

6.19. If an email or an attachment appears suspicious, users should refrain from responding to the message and promptly notify the IS Officer or DPO.

NB: Users are permitted to access their corporate email using personal computers/laptops and mobile devices to enhance productivity and convenience. However, Users must ensure that all personal devices used to access and use corporate email are protected at all times – refer to Use of XYZ IT

Services on Personally Owned Devices. NB: In case of lost or misplaced devices, users must immediately notify the IT Help Desk or the SBU / division IT representative and change the Password.

NB: If in case Users notice XYZ, its Suppliers' or Customers' sensitive or confidential information present in company-supplied collaboration tools or publicly accessible websites, social media sites, mailing lists, or news groups, such Users must promptly report such content to the IT Help Desk.

7. INTERNET USAGE

7.1. Users are encouraged to use the Internet to further the goals and objectives of XYZ as well as for fulfilling business and role-oriented tasks. However, Users are solely accountable for the content they disseminate or information they access through the Internet services provided by XYZ.

7.2. Users must only use XYZ-provided Internet services for business-related activities. Illegal or non-business use of such service is not permitted.

7.3. Internet Service Logging and Monitoring

All user activity performed using the XYZ Internet service is recorded, maintained, and analyzed to identify exceptions and unauthorized activity, and to take remedial or disciplinary actions against non-compliance.

7.3.1. Users must not alter or attempt to alter their Internet access settings and configurations on the company-provided Laptop and Desktop computers.

7.3.2. Users are prohibited from installing or using applications that bypass XYZ Internet security controls.

7.3.3. Users are prohibited from installing or using file sharing, peer-to-peer, chat, and messaging applications on the company-provided Laptop and Desktop computers.

7.3.4. Users must not use the XYZ Internet connection to download or execute unauthorized content or personal content from the Internet.

7.3.5. Use of XYZ-provided dongles is strictly limited to be used, only when physical access to the XYZ company network is not possible either via a location-based wired network connection or via a location-based wireless network connection.

7.3.6. Users should regularly update themselves about online fraud schemes and other Internet-based threats. Users must be careful and exercise reasonable skepticism when the Internet, especially when accessing websites or applications.

7.3.7. Users should never use commercially available free or paid Internet VPN applications on

PCs, Laptops, Smartphones, and Tablet devices when accessing and transacting with XYZ Applications, Email, and XYZ-provided file storage locations (eg. OneDrive/SharePoint on Office 365).

7.3.8. Users must notify the IT Help Desk or the SBU / division IT representative in case of any errors or exceptions observed while accessing the Internet.

7.3.9. Users must not create XYZ-related pages or social media accounts or post XYZ-related content on social sites or any other internet-facing site or design any website on their own, to contain XYZ-related content, and, in case there is a business requirement, the user should route such requirements **Group Corporate Communications.**

7.4. Users are prohibited from using the Internet in a manner that is disruptive, harmful, or offensive to others. This includes accessing, displaying, transmitting, or downloading politically sensitive material or obscene content, as well as using ethnic slurs or engaging in any activity that may be construed as harassment or disparagement of others.

7.5. Users must exercise caution to avoid violating laws, including the Computer Crimes Act, copyright laws, intellectual property rights, licensing agreements about material obtained from the Internet, and any other applicable laws.

7.6. All internet sites accessed through the company networks will be recorded. The information recorded by the monitoring system includes the username, source IP address, destination address, date and time, applications, and service.
The TS will restrict access to specific internet websites and protocols deemed unsuitable for XYZ's corporate environment.

7.7. Users may access blocked sites or services with permission if deemed appropriate and necessary for business-related purposes.

7.8. To request access to a blocked site, users must submit a request specifying the website URL to the SOC, NOC, and Governance, providing details of the business requirement, along with approval from their immediate supervisor and/or department head.

NB: Users are advised to be careful when accessing the Internet from outside the office, using company-provided Laptops, or using the user's own personal computers, laptops, or other mobile computing devices. A knowledgeable attacker can use sophisticated techniques to lure the User to bogus websites, install unauthorized software, spread computer viruses, steal passwords, and/or gain access to sensitive company and personal information.

8. REMOTE ACCESS SERVICE

The remote access service provides identified Users access to email and other business applications from outside the office network. Such access granted shall be based on the business need and according to the least privileges necessary to carry out assigned job responsibilities. For users requiring remote access, a formal request to the TS with appropriate approval and justification is

mandatory.

8.1. Users are encouraged to use the remote access facilities to enhance productivity and improve convenience. However, it is the User's responsibility to make sure that the remote access service is used in a responsible, reliable, and secure manner, only for the purpose and intention of the company.

8.2. All remote computer equipment and mobile devices used for business activity, whether personal or company-provided, must be implemented with reasonable physical and technical security controls to avoid unauthorized access or misuse.

8.3. Such computers/devices must have appropriate antivirus software installed, updated, and effectively operating.

8.4. Such computers/devices must have a company-approved personal firewall installed, updated and effectively operating.

8.5. Anti-virus and Personal Firewalls

Most modern computer/device operating systems support anti-virus technologies and personal firewalls. The anti-virus and personal firewalls will monitor the system and connections for abnormal behavior and block / raise alerts.

8.5.1. The user must ensure that the computers/devices are running the latest version of the computer / device-supported operating system. Users must further ensure that the latest device operating system patches and updates are downloaded and installed, as soon as they are available from the Original Equipment Manufacturer (OEM). (User must present their machine based on a planned schedule communicated by the Site IT team, to check the above – since user cannot ensure this)

8.5.2. Users must not tamper with or change the remote connection settings or configurations.

8.5.3. Users must switch off the remote access service when not in use.

8.6. Bluetooth & Wireless

Most modern computers/devices are equipped with Bluetooth and Wireless technology to enable easy and flexible interconnection of computers and devices. However, due to weak security, these technologies are relatively easily compromised to gain unauthorized access to computers/devices. Therefore;

8.6.1. Users must ensure that their computers/devices are not connected to any other network while connected to the Company network.

E.g.: connect to a Broad Band Dongle, whilst connected to the XYZ private corporate WIFI or wired (LAN) network.

8.6.2. Users must not leave computers/devices used for remote access unattended. When not in use, such computers/ devices must be properly locked down and secured.

8.6.3. In case of lost or misplaced computers/devices, users must immediately the IT Help Desk or the SBU / division IT representative and change the Password.

8.7. Users are prohibited from making any modifications to the remote access connection without the explicit approval of the SOC, NOC, and Governance teams.

8.8. Remote users must immediately report any incident or suspected incident of unauthorized access or disclosure of company resources, databases, networks, or information (refer to section Incident Reporting).

NB: Users must avoid using public computers (such as shared computers at Internet Cafes) to access company resources and IT systems. Users must also be careful when using their computers/devices in public places (airport lounges, coffee shops, while in transit, etc.) to avoid perpetrators from observing the screen and capturing confidential information.



USE OF XYZ IT SERVICES ON COMPANY-OWNED DEVICES

9.1 IT Devices

XYZ provides IT devices, both laptops and desktops, that run the latest standard operating systems and patches as per the IT standards, to all its employees. The provisioning of a user ID by Technology Services immediately follows the provision of a personal computer or device to access XYZ's different application systems as per the requirement set by the Manager of that employee.

The use of these devices outside Office Premises along with the granting of broadband internet facilities, is allowed based on the approval of the Manager of that employee.

9.2 MOBILE DEVICES (TABLETS AND SMARTPHONES)

9.2.1 Only mobile devices owned by XYZ SBUs and managed by XYZ Technology The Services Team is allowed to connect to specially defined Wireless networks within the XYZ MPLS Network.

9.2.2 Only the XYZ-defined portfolio of Applications accessible from the App Store over the Public Internet will be available for consumption by XYZ-owned mobile devices.

9.3 Users are solely responsible for safeguarding their device from access by any party other than those authorized to access XYZ information and systems. If the device changes hands, the user must inform the IT Help desk and ensure access to XYZ information and systems is revoked.

9.4 Users must ensure that company-sensitive information is not stored or maintained on such personal computers/devices or backed up through personal cloud storage services.

9.5 Personal Cloud Storage Services include and are not limited to consumer versions of:

- Dropbox
- Box
- Apple iCloud
- Google Drive
- Microsoft Personal OneDrive

9.6 Users are not authorized to modify any device security settings. If there is a business justification for such changes, users may contact the Smart Desk with necessary approvals to request the necessary modifications to the device.

9.7 Users must be aware that such devices contain company data and take appropriate action to protect the device from being lost or stolen. If a IT Device is lost or stolen the user must immediately notify the IT Department.

9.8 All mobile devices should be returned to the TS for repairs, replacement, disposal, or exchange. Users are not permitted to hand over the device directly to a vendor or any third party for any purpose without prior approval from the Technology Services.

9.9 User should ensure that data on the mobile device is regularly backed. Backups of confidential data should be stored only in Official OneDrive.

9.10 Users are strictly prohibited from using mobile devices in a manner that is disruptive, harmful, or offensive to others and/or in any way that violates local or international laws.

9.11 Company-provided mobile devices should not be altered or augmented in any way, such as upgrading the hard disk, adding additional RAM, or installing a flash card reader, without prior approval from the Technology Services. Furthermore, any such modifications must be only carried out by the Technology Services.

9.12 Company-provided mobile devices are designated for official use only. Users are strictly prohibited from allowing these devices to be used by friends or family members, or from loaning them to any other party.

9.13 General use and care guidelines for mobile devices include:

- Ensure that the virus guard is updated with the latest definition files.
- Do not leave the mobile device unattended in public areas (e.g., restaurants, meeting rooms, airports, or a hotel lobby, etc.).
- Avoid leaving the mobile device in view in an unattended vehicle, even for a short period.
- Store the mobile device in locations that do not expose it to extreme heat or cold (e.g., inside a vehicle).
- Avoid exposing the mobile device to excessive vibration or shocks or placing objects on top of it.
- Refrain from using the mobile device while traveling in a vehicle on uneven roads.
- Exercise caution when displaying sensitive information in public spaces and position the screen to prevent others from viewing it whenever possible.
- Be mindful of shoulder surfing.
- Use a protective carrying case when traveling with a mobile device.
- It is the sole responsibility of the user to take proper care of the allocated mobile devices.

* Note that what is approved for official use is **Microsoft OneDrive for Business.** Thus, sharing of information with XYZ personnel as well as external parties should only be done via **Microsoft OneDrive for business.**

NB: In case of any security breach, suspected or actual, Users must immediately notify the IT Help Desk or the SBU / division IT representative so that appropriate remedial action can be taken.



USE OF XYZ IT SERVICES ON PERSONALLY OWNED DEVICES

XYZ defines BYOD as the usage of personally owned devices by connecting to the Private Network of XYZ. **This is not allowed**.

Usage of XYZ IT services on personally owned devices is limited for email only with the objective of increasing the productivity. All users (except for any users group approved by the management) are requested to use XYZ IT and application services through XYZ provided IT devices only.

10.1. PERSONAL COMPUTERS

10.1.1. In the event for users where management has allowed the usage of personally owned computers shall follow the below requirements:

- Users must use personally owned personal computers only with the latest operating systems and patches approved by XYZ Technology Services as per the IT standards document circulated to the IT Administrator.

- Users must refrain from using pirate software, pirate licenses or security-by-passed (jail-broken) devices appended (such as broad band network devices) to their personal computers. If any data breach or security breach happens through a personal device which has a pirate software or pirate licenses installed, the individual must take the responsibility.

- User must connect only via the public Internet for which XYZ will grant that facility and must never connect to the private network of the XYZ Business Premises they are stationed at.

- User must ensure that these computers have a company approved antivirus, personal firewall and mobile device management software installed, updated and effectively operating.

- All data files deemed to be owned by the company and used or created by this class of individuals using such personally owned computers, must be stored in the cloud-storage locations provided by the company with due rights-protection set by the supervising functional or department managers employed by the company, and should not be kept stored in the personally owned computers.

- Users should never use commercially available free or paid Internet VPN applications on PCs and Laptops, when accessing and transacting with XYZ Applications, Email and XYZ provided file

storage locations (eg. OneDrive/SharePoint on Office 365).

- User should never install or use torrent on the personal computers which access XYZ applications, email and XYZ provided file storage locations.

- Refer to XYZ-TS-Personal Device Acceptable Usage Guideline for further information.

10.2. MOBILE DEVICES (TABLETS AND SMARTPHONES)

10.2.1. Personally owned mobile devices are allowed to connect only via the public internet and connection to the XYZ Private Network is blocked for these devices.

10.2.2. The XYZ defined portfolio of Applications are accessible from the App store over the Public Internet and will be securely made available for consumption by personally owned mobile device users.

10.3. Users are solely responsible to safeguard their personally owned device from access by any party other than those authorized to access XYZ information and systems, during the period they work for XYZ.

10.4. Users must ensure that company sensitive information is not stored or maintained on such personal computers / devices or backed-up through personal cloud storage services. The provision of a Virtual Desktop Interface or a Company App, wherever applicable, and locking access only to that Virtual Desktop Interface or App is expected to ensure this control.

10.5. Users should never use commercially available free or paid Internet VPN applications on Smartphones and Tablet devices, when accessing and transacting with XYZ Applications, Email and XYZ provided file storage locations (eg. OneDrive/SharePoint on Office 365).

* Note that what is approved for official use is **Microsoft OneDrive for Business.** Thus, sharing of information with XYZ personnel as well as external parties should only be done via **Microsoft OneDrive for business.**

NB: In case of any security breach, suspected or actual, Users must immediately notify the IT Help Desk or the SBU / division IT representative so that appropriate remedial action can be taken.



USE OF FLASH DRIVES AND OTHER REMOVABLE MEDIA FOR STORAGE OF COMPANY-OWNED DATA

Flash drives and other removable data-storage media such as USB hard disks, CDs or DVDs are susceptible to theft, loss, and damage.

Therefore, users must be mindful of how to use them.

The company sets the following rules to ensure that these media are used safely and effectively by its employees.

11.1. The usage of privately owned CDs and DVDs by employees and associates is not allowed. Only company-owned CDs and DVDs are allowed for use with IT support team supervision and the media must be stored by the management of the Business Unit.
11.2. Only the use of company-owned encrypted flash drives and USB disk drives maintained and distributed by the IT support team is allowed, in each and every Business Unit of XYZ. These drives will be provided by the Business Unit for the duration of usage by the employee, via IT Support. At the end of the period, the drives must be cleared of data by the employee and handed over back to IT support for testing and storage.

Additionally, it is strongly recommended that all user-created data or document files are rights-protected at the point those files are created or modified by the user.



12. INCIDENT REPORTING

12.1. Users bear the responsibility of promptly reporting any suspicious events in the company's information security and any instances of potential misuse or violation of this policy to their respective unit head and the SOC through helpdesk ticket or e-mail: SOC@xyzholdings.com.
12.2. An information security incident is any event that threatens the confidentiality, integrity, or availability of company information or information systems. Examples include, but are not limited to:

- Unauthorized access to data or systems;
- Data breaches or leaks;
- Loss or theft of company devices or data;
- Malware or ransomware attacks;
- Phishing attempts; and
- Any activity that compromises network security.

12.3. All users must report suspected information security incidents immediately upon discovery.
12.4. Incidents must be reported to the IS Officer using the designated reporting channels.
12.5. All incident reports will be treated as confidential. The company will take appropriate steps to protect the identity of the user reporting the incident
12.6. Adherence to this policy is mandatory. Failure to report suspected incidents promptly may result in disciplinary action.

EVALUATION AND MONITORING

12.7. Prior to gaining access to XYZ IT systems and services, all Users shall review and provide confirmation that they have read and understood the contents of this policy and they will comply accordingly.

12.8. Process and tools shall be deployed to monitor and enforce compliance to this policy, Information Security Policy and IT Governance and Management Policy.

12.9. The relevant authorized personnel of the Company shall have the right to access the content in email, intranet sites and data-storage facilities of the Company, created and maintained by and the data content in applications (such as SAP) to which a User is given access to.

13. NON-COMPLIANCE

13.1. Report non-compliance of the policy via one of the following channels.

- Speak to your site IT personnel or log a ticket in the IT Help Desk
- Speak to your SBU, Divisional or Group Code Officer
- Lodge a complaint via the DNA Helpdesk
- Log on to xyzhelpdesk.ethicspoint.com.
- Call 0112 430 430 and dial 855 867 7899 at the English prompt.

13.2. The XYZ Ethics Committee and other accountable parties will maintain the confidentiality of all parties involved in the recording and investigation of the complaint.

13.3. It is your responsibility to support ongoing investigations by being open, honest and maintaining confidentiality, in the event you are contacted by a member of the XYZ Ethics Committee.

13.4. Retaliation against an individual for; lodging/ attempting to lodge a complaint, supporting a victim, or participating in investigations; amounts to non-compliance of the XYZ DNA (Code of Conduct) and the policy.

13.5. Reporting unfounded false allegations with wrongful intentions of malice, in a bid to tarnish reputations, amounts to non-compliance of The XYZ DNA.

13.6. For any clarifications, please contact the DNA Helpdesk on policyinfo@xyzholdings.comthe Site IT Support Specialist or the IT Help Desk on Help@xyzholdings.com

14. RESPONSIBILITY

14.1. It is the responsibility of every unit head / manager to ensure all employees in the Executive Cadre are educated on and adheres to this policy; and take immediate and appropriate action against violations of the policy, if brought to their attention or observed.

15. VALIDITY OF THE XYZ INFORMATION SYSTEM USAGE POLICY

This policy has been reviewed and approved by the Group Board of XYZ.
It will be annually reviewed in response to changes in the IT environment, relevant legislation,

CS5292 W6 · D15 · sanitised for teaching

contractual arrangements, good practices or in response to an identified failing in its effectiveness.

DEFINITIONS

- Anti-Virus - Software used to detect and prevent malicious or unauthorized program code such as viruses from being transmitted over the network or affecting computer systems.
- Encryption - Encryption is the process of transforming information using an algorithm to make it unreadable to anyone except those intended to have access to that information. Decryption is the process of making the encrypted information readable again.
- Firewall - A hardware device or a software application running on a server deployed to isolate and protect sensitive networks or systems from un-trusted networks.
- Proxy Server - Proxy Server is a security system used to protect internal users accessing the Internet from external threats.
- XYZ - XYZ Holdings (Private) Limited and its subsidiaries, affiliates and joint venture partners.
- SBU - Strategic Business Unit, a subsidiary or affiliate of XYZ
- Division - A division within an XYZ SBU, including but not limited to Finance, HR, IT, Innovation etc.
- Third-Party - Any company that is not part of XYZ or its joint venture partnerships.
- IT Help Desk - A function within Technology Services that is dedicated to support Users and respond to User requests and complaint.